

외부주문보안 지침



주식회사 모인

개정 이력

[illegible]

외부주문 보안 지침

소관부서 : 정보보안팀

제1장 총칙

제1조(목적) 이 지침은 모인 주식회사 모인(이하 “회사”라 한다)의 외부업체의 보안 관리에 관한 사항을 규정하는 정책시행 문서로서 외부업체의 단계별 보안 요구사항을 준수하기 위한 기준으로써 활용함을 그 목적으로 한다.

제2조(적용 범위) 이 지침은 전자금융거래를 위한 외부주문등의 계약에 의하여 서비스를 공급하는 업체 및 개인을 대상으로 한다.

제3조(용어의 정의) 이 지침은 다음 용어 정의를 따른다.

- 1 “외부업체”란 전자금융보조업자를 포함한 위탁 계약에 의하여 정보처리시스템과 관련된 업무에 대하여 서비스를 공급하는 업체를 의미한다.
- 2 “외부직원”이란 IT업무 수행을 위하여 계약된 외부업체 직원으로, 회사의 정보자산을 이용하여 서비스와 기타 업무를 대행하는 자를 의미한다.
- 3 “전자금융보조업자”란 제1호에 따른 외부업체 중 「전자금융거래법」 제2조제5호에 해당하는 자로 전자금융거래와 관련된 IT업무의 전부 또는 일부를 지원하거나, 해당 정보처리시스템을 운영하는 사업자를 의미한다.
- 4 “위탁”이란 회사가 인가 등을 받은 금융업을 영위하기 위하여 제3자(개인을 포함한다)의 용역 또는 시설 등을 계속적으로 활용하는 행위를 의미한다.
- 5 “개인(신용)정보 수탁자(이하 ‘수탁자’라 한다)”란 개인(신용)정보 처리 업무를 위탁하여 처리하는 자를 의미한다.

제2장 역할 및 책임

제4조(정보보호최고책임자)

- 1 정보보호최고책임자(이하 “CISO”라 한다)는 외부직원 보안 관리 업무에 대한 총괄 책임을 가진다.
- 2 CISO는 외부직원에 대한 보안통제 사항을 규정하여 정보보호 담당자가 정보보안 활동을 할 수 있도록 지원한다.

제5조(정보보호 담당자)

- 1 정보보호 담당자는 외부직원에 대한 보안관리 활동을 수행하고, 그 결과를 CISO에게 보고하여야 한다.
- 2 정보보호 담당자는 외부직원 계약부터 종료 시까지 단계별 보안통제 활동이 적절하게 이루어 지도록 관리·감독한다.

제6조(외부업체 계약부서)

- 1 외부직원을 활용하는 사업에 대하여 계약을 수행하는 부서로 과업지시서 및 계약서에 보안요구사항이 포함되도록 관리할 책임이 있다.
- 2 외부업체 계약부서(이하 ‘계약부서’ 라 한다)는 외부업체 계약 시 업무를 수행하게 되는 외부직원을 대상으로 [보안서약서]를 징구 하여야 한다.

제7조(외부업체 관리부서)

- 1 외부직원을 활용하는 사업에 대한 관리 책임이 있는 부서로 외부직원 및 이들이 소속된 업체를 이 지침에 따라 관리할 책임이 있다.
- 2 외부업체 관리부서(이하 ‘관리부서’ 라 한다)는 외부직원에게 보안 준수사항 및 사고 시 보고 절차 등을 명확히 공지하여야 한다.

제3장 외부업체 보안 관리

제8조(외부업체 현황 관리)

- 1 회사는 IT업무 범위 내에서 발생하고 있는 다음 각 호의 업무 위탁 및 외부 시설·서비스의 위탁 현황을 명확히 식별하여야 한다.
 - 1) IT 및 보안 업무 위탁
 - 2) 개인(신용)정보 처리 위탁
 - 3) 외부 시설(IDC 등) 이용 위탁
 - 4) 외부 서비스(클라우드 등) 이용 위탁
 - 5) 전자금융보조업자 제휴, 위탁

회사는 제1항에 따른 위탁 현황에 대해 외부업체명, 위탁하는 업무 내용, 관리부서 및 담당자명, 위탁 및 서비스 이용 기간 등을 < 외부업체 위탁 현황 목록>에 작성하고, 늘 최신의 상태가 유지되도록 하여야 한다.

제9조(전자금융거래 위탁 시 보안 관리) 전자금융거래를 위한 위탁 시 준수하여야 하는 단계별(입찰,

계약, 수행, 완료) 보안 관리 사항은 제4장 및 제5장에서 정한 바를 따른다.

제10조(전자금융보조업자 보안 관리)

1 회사는 위탁 계약 중인 전자금융보조업자를 대상으로 다음 각호의 사항을 준수하여야 한다.

- 1) 전자금융보조업자에 대한 재무건전성을 연1회 이상 평가하여 재무상태 악화에 따른 도산에 대비하고 전자금융보조업자의 주요 경영활동에 대해 상시 모니터링을 실시
- 2) 전자금융보조업자가 제공하는 서비스의 품질수준을 연1회 이상 평가할 것
- 3) 전자금융보조업자가 사전 동의 없이 다시 IT 계약을 체결하거나 계약업체를 변경하지 못하도록 하고, 사전 동의 시 해당 계약서에 제9조의 사항을 기재하도록 통제
- 4) 회사와 전자금융보조업자 간의 접속은 전용회선(전용회선과 동등한 보안수준을 갖춘 가상의 전용회선을 포함한다)을 사용
- 5) 그 외 단계별(입찰, 계약, 수행, 완료) 보안 관리 사항은 제4장 및 제5장에서 정의한 사항

2 회사는 제1항제1호 및 제2호의 평가결과를 금융감독원장에게 보고하여야 한다.

제11조(수탁자 보안 관리) 개인(신용)정보 처리업무 위탁에 대한 보안관리 사항은 「개인(신용)정보보호지침」에서 정한 바를 따른다.

제12조(개발 보안 관리)

1 외부자에게 개발업무를 위탁하는 경우 사내 보안통제 사항을 준수하도록 통제하여야 한다.

2 외부자에 의한 응용프로그램 분석, 설계 구현은 회사내 개발자와 동일한 개발 프로세스를 준수하여 개발하여야 한다.

3 외부업체 관리부서는 외부자에 의해 개발된 응용프로그램이 보안요구사항을 준수하여 개발되었는지 점검하여야 한다.

제13조(클라우드컴퓨팅서비스 보안 관리) 클라우드컴퓨팅서비스 이용에 대한 위수탁 운영 기준, 안전성 확보조치 등 보안관리 사항은 「정보시스템 보안 지침」 제5장 제5절 클라우드컴퓨팅서비스에서 정한 바를 따른다..

제4장 입찰 및 계약 시 보안 관리

제14조(입찰 시 보안)

1 회사는 입찰공고 이전에 투입이 예상되는 자료와 장비 가운데 보안관리가 필요한 사항에 대하여 회사의 내부관리기준과 관련 법규를 검토하고, 필요한 보안요구사항을 마련하여 제안요청서에 반영하여야

한다.

- 2 계약부서는 입찰공고 시에 회사가 자체 작성한 중요정보, 부정당업자 제재조치, 기밀유지 의무 및 위반 시 불이익 등을 정확히 공지하거나, 제안요청서에 반영하여야 한다.
- 3 회사는 제안서 평가요소에 자료, 장비, 네트워크 보안대책, 중요정보 관리방안 등 보안관리계획의 평가항목 및 배점기준을 마련하고, 계약부서는 이를 제안요청서에 반영하여야 한다.
- 4 외부업체는 보안관리 방안을 제안서 상에 명시하거나, 첨부하여야 하며, 계약부서는 제시한 용역사업 전반에 대한 보안관리 계획의 타당성을 검토하여 필요 시 추가적인 방안을 요구하여야 하며, 사업자 선정 시 이를 반영하여야 한다.

제15조(계약 시 보안)

- 1 계약부서는 계약서 작성 초기 단계부터 다음 각 호의 보안 요구사항 포함여부에 대한 검토를 실시하여야 한다.

- 1) 정보보호 관련 법률 준수 (개인정보 처리 관련 등)
- 2) 정보보호서약서 제출 (비밀유지, 정보보안 책임 등)
- 3) 위탁 업무 수행 직원 대상 주기적인 정보보안 교육 및 점검 수행
- 4) 업무수행 관련 취득한 중요정보 유출 방지 대책
- 5) 회사와 이용자 간 암호화 정보 해독 및 원장 등 중요 데이터 변경 금지
- 6) 접근매체 위·변조, 해킹, 개인정보유출 등에 대비한 보안대책 수립
- 7) 정보관리의 취약점을 최소화하고 보안유지를 위한 내부통제방안을 수립·운영
- 8) 정보처리시스템 장애 등 서비스 중단에 대비한 비상대책 수립
- 9) 중요 전산자료의 백업(backup)자료 보존 및 백업설비 확보 등 백업대책 수립
- 10) 투입인력에 대해 회사의 사전 동의 없이 교체 금지
- 11) 인력변경 시 인수인계에 관한 사항 등을 포함한 업무수행인력 관리방안 수립
- 12) 업무수행인력에 대하여 사전 신원조회 실시 또는 대표자의 신원보증서 징구
- 13) 외부업체가 하도급 계약 체결 시 원래 사업계약 수준의 비밀 유지 조항 포함
- 14) 인원·장비·자료 등에 대한 보안조치 사항과 정보유출 및 부정당업자에 대한 손해배상 내용, 보안사고발생에 따른 보고 의무
- 15) 자체 보안성검토 및 정기 보안점검 실시

- 2 계약부서는 용역사업에 투입되는 자료와 장비 등에 대해 대외보안이 필요한 경우, 보안의 범위와 책임을 명확히 하기 위해 사업수행계약서와 별도로 다음 각 호의 사항이 포함된 비밀유지계약서를 작성하여야 한다.

- 1) 비밀정보의 범위
- 2) 보안준수 사항

- 3) 위반 시 손해배상 책임
- 4) 지적재산권 문제
- 5) 자료의 반환 및 폐기 등

제5장 수행 및 완료 시 보안 관리

제16조(외부직원 관리)

- 1 관리부서는 용역사업 참여인원에 대해서는 ‘정보 유출’ 방지 조항 및 개인의 자필 서명이 들어간 [보안서약서]를 징구하여야 한다.
- 2 관리부서는 용역사업 수행 전 참여인원에 대해 다음 각호에 대한 보안교육을 실시하여야 한다.
 - 1) 법적 또는 회사 내규에 따른 비밀유지 의무 준수
 - 2) 위반 시 처벌내용
 - 3) 유출 금지 대상정보 및 정보 유출 시 부정당업자 제재조치
 - 4) 그 외 CISO가 필요하다고 인정하는 사항
- 3 회사는 사업 수행 중 외부직원에 대한 보안점검을 실시하여, ‘유출금지 대상 정보’ 외부유출 여부를 확인하여야 한다.

제17조(자료관리)

- 1 관리부서는 계약서 등에 명시한 중요정보를 업체에 제공할 경우, 자료관리 대장을 작성하여 인계자와 인수자가 직접 서명한 후 제공하고, 사업완료 시 관련자료를 회수하여야 한다.
- 2 용역사업 관련자료 및 사업과정에서 생산된 모든 산출물은 회사의 파일 서버에 저장하거나, 회사가 지정한 PC에 저장하고 관리하여야 한다.
- 3 용역사업 관련자료는 인터넷 웹하드, P2P 등 인터넷 자료공유사이트와 개인 메일함에 저장하는 것을 금지하며, 회사와 외부업체간 이메일을 이용해 전송이 필요한 경우에는 회사 이메일 시스템을 이용하고, 첨부자료 중 이용자 정보, 비밀정보 등 중요정보가 포함된 자료는 암호화 후 전송하여야 한다.
- 4 회사가 제공한 사무실에서 외부업체가 용역사업을 수행할 경우, 유출금지 대상 정보가 포함된 자료는 매일 퇴근하기 전 잠금 장치가 된 곳에 보관하여야 한다.
- 5 용역사업 수행으로 생산되는 산출물 및 기록은 회사가 인가하지 않은 비인가자에게 제공, 대여, 열람을 금지하여야 한다.

제18조(사무실·장비 관리)

- 1 용역사업 수행장소는 회사의 전산실 등 중요시설과 분리하고 CCTV, 잠금장치 등 비인가자의 출입통제

대책을 마련하여야 한다.

- 2 외부업체에 의한 정보처리시스템의 개발업무에 사용되는 업무장소 및 전산설비는 내부 업무용과 분리하여 설치·운영하여야 한다.
- 3 회사는 용역업무를 수행하는 공간에 대한 보안점검을 정기적으로 실시한다.
- 4 외부직원이 노트북 등 관련 장비를 외부에서 반입하여 내부망에 접속 시 악성코드 감염여부 및 장비반출 시마다 자료의 무단반출 여부를 확인하여야 한다.
- 5 인가되지 않은 USB 등 보조저장매체의 사용을 금지하며, 산출물 저장을 위하여 반드시 필요한 경우에는 회사의 승인을 받은 후에 사용하여야 한다.

제19조(내·외부망 접근 관리)

- 1 회사는 개발시스템과 운영시스템을 분리하고, 외부업체는 업무상 필요한 서버에만 제한적으로 접근을 허용하여야 한다.
- 2 외부직원이 정보처리시스템 이용이 필요한 경우는 다음 각 호의 사항을 준수하여야 한다.
 - 1) 외부직원 사용자계정(ID)은 하나의 그룹으로 등록하고, 계정별로 정보처리시스템 접근권한을 차등 부여하며, 허용되지 않은 회사의 내부분서 접근을 금지한다.
 - 2) 계약의 종료, 외부직원의 퇴사, 이동 등으로 인하여 계정별로 부여된 접속권한이 더 이상 필요하지 않다면 즉시 해지하거나 계정을 폐기하여야 한다.
 - 3) 외부직원에게 부여한 계정은 별도로 기록 관리하고, 수시로 해당 계정을 통해 저장된 자료와 작업이력을 확인한다.
 - 4) 회사는 내부 서버 및 네트워크 장비에 대한 접근기록 이상 여부를 정기적으로 점검하여야 한다.
- 3 외부업체가 사용하는 PC는 인터넷 연결을 금지하되, 사업수행 상 연결이 필요한 경우에는 회사의 보안통제를 전제로 내부통신망과 분리된 인터넷PC에서 제한적으로만 허용한다.
- 4 외부업체가 사용하는 전산망에서 P2P, 웹하드 등 인터넷 자료공유사이트로의 접속을 원천 차단하고 내부통신망에서의 공유폴더 사용을 금지하여야 한다.

제20조(외부업체 보안점검)

- 1 회사는 외부업체의 법령, 계약서, 내부 정책에서 명시한 보안 요구사항에 대한 준수여부를 주기적으로 점검하여야 한다.
- 2 회사는 [별표]의 중요 점검사항에 대해서는 외부업체를 대상으로 매일 점검을 수행하여야 한다.
- 3 제1항 및 제2항에 따라 외부업체는 발견된 문제점에 대해 개선계획을 수립하고, 이행하여야 한다.

제21조(완료 시 보안)

- 1 회사는 외부업체의 계약만료, 업무 종료, 담당자 변경 시 다음 각 호의 사항을 수행하여야 한다.

- 1) 정보자산 반납
 - 2) 정보시스템 접근계정 삭제
 - 3) 접근권한의 회수 또는 변경
 - 4) 공용 계정 비밀번호 변경
 - 5) 출입증 회수 및 출입권한 삭제 등
- 2 사업 완료 후 생산되는 최종산출물 등 대외보안이 요구되는 자료는 대외비 이상으로 관리하고, 불필요한 자료는 폐기하여야 한다.
- 3 관리부서는 용역업체에 제공한 자료, 장비, 중간산출물, 최종산출물 등 용역과 관련된 모든 자료를 회수하며, 업체에 복사본 등을 별도로 보관하는 것을 금지한다.
- 4 관리부서는 용역사업 완료 후, 업체 소유의 PC 또는 서버의 하드디스크, 이동식 저장장치 등 전자기록 저장매체는 복원이 불가능한 방법으로 완전 삭제 후 반출한다.
- 5 용역사업 관련자료 회수 및 삭제조치 후, 복사본 등 용역사업관련 자료를 보유하고 있지 않다는 업체 대표자 명의의 확인서를 받거나, 외부직원으로부터 파기확인서를 받는다.

부칙

제1조(시행일) 이 지침의 시행일은 대표이사가 승인한 날로 한다.

* 전자금융보조업자 대상 연 1회 재무건전성 및 서비스 품질수준 점검 사항[별표]

중요 점검사항

연번	점검 항목
1	이용자 정보의 조회·출력에 대한 통제 및 이용자 정보 조회시 사용자, 사용일시, 변경·조회내역, 접속 방법 기록·관리
2	테스트시 이용자 정보 사용금지(부하 테스트 등 사용이 불가피한 경우 이용자 정보를 변환하여 사용하고 테스트 종료 즉시 삭제)
3	운영시스템 접속·사용 통제
4	내부통신망의 비인가 전산장비·무선통신 접속 통제(정보처리시스템을 이용한 통제 장치 마련시 통제 장치에 대한 일일점검으로 대체 가능)
5	전산자료 및 전산장비 반출·반입 통제
6	전산실 등 출입자 관리기록부 기록·보관
7	인터넷(무선통신망 포함) 사용 통제(정보처리시스템을 이용한 통제 장치 마련 시 통제장치에 대한 일일 점검으로 대체 가능)
8	운영체제 및 악성코드 치료프로그램을 최신으로 유지
9	USB 등 보조기억매체 사용 통제
10	단말기에 이용자 정보 등 중요정보 보관 금지